



INTERN REPORT

Vulnerability Assessment Findings Report

Business Confidential

Date: May 31th, 2026
Project: 897-19
Version 1.0

Table of Contents

Table of Contents	2
Confidentiality Statement.....	3
Disclaimer.....	3
Contact Information.....	3
Assessment Overview	4
Finding Severity Ratings	5
Scope.....	6
Scope Exclusions	6
Client Allowances.....	6
Executive Summary	7
Security Strengths	8
SIEM alerts of vulnerability scans	8
Security Weaknesses	Error! Bookmark not defined.
Vulnerabilities by Impact	9
External Penetration Test Findings.....	10
Missing Security Headers	10
Insecure Cookie Attributes	12
Information Disclosure via HTTP.....	14

Confidentiality Statement

This document is the exclusive property of Demo site (DS) and Future Interns (FI). This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both DS and FI.

FIs may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

This assessment was performed on the Demo Site (DS). The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. FIs prioritized the assessment to identify the weakest security controls an attacker would exploit. FIs recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Contact Information

Name	Title	Contact Information
Demo Site		
John Smith	VP, Information Security (CISO)	Office: +91xxxxxxxxx Email: john.smith@demo.com
Jim Smith	IT Manager	Office: +91xxxxxxxxx Email: jim.smith@demo.com
Joe Smith	Network Engineer	Office: +91xxxxxxxxx Email: joe.smith@demo.com
Future Interns		
Sujan Kumar C	Co-Founder & Proprietor	Office: +91xxxxxxxxx Email: sujan@futureinterns.com
Prajwal Singh	Co-Founder	Office: +91xxxxxxxxx Email: prajwal@futureinterns.com
Anwar Khan	Penetration Tester	Office: +91xxxxxxxxx Email: anwar@futureinterns.com

Assessment Overview

From May 20th, 2019 to May 29th, 2019, DS engaged FI to evaluate the security posture of its infrastructure compared to current industry best practices that included an vulnerability assessment.

Phases of penetration testing activities include the following:

- Planning – Customer goals are gathered and rules of engagement obtained.
- Discovery – Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- Reporting – Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.

Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS score range that are used throughout the document to assess vulnerability and risk impact.

Severity	CVSS V3 Score Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0-8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0-6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1-3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

Scope

Assessment	Details
External Penetration Test	http://testphp.vulnweb.com

Scope Exclusions

Inscope

- ☐ Public-facing pages only
- ☐ Passive scanning
- ☐ Header checks
- ☐ Configuration analysis

Out of scope

- ☐ Login bypass
- ☐ Exploitation
- ☐ Brute force attacks
- ☐ Denial-of-Service (DoS)
- ☐ Any activity that can harm the website

Client Allowances

DC did not provide any allowances to assist the testing.

Executive Summary

This report presents the findings of a passive vulnerability assessment conducted on the publicly accessible website <http://testphp.vulnweb.com>.

The objective of the assessment was to identify common security weaknesses using ethical, non-intrusive techniques without performing any exploitation or active attacks.

The assessment focused on publicly visible configurations, HTTP security headers, cookies, and exposed services using industry-standard tools.

Based on the analysis, several low to medium risk issues were identified. Addressing these findings will help improve the overall security posture of the website and reduce potential attack vectors.

FINDINGS SUMMARY

The following table describes how TCMS gained internal network access, step by step:

Step	Action	Recommendation
1	Missing Security Headers – Recommended HTTP security headers were not present in server responses.	Configure recommended HTTP security headers such as Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options on the server.
2	Insecure Cookie Attributes – Cookies were observed without important security flags such as HttpOnly and Secure.	Set secure cookie attributes including HttpOnly, Secure, and SameSite from misuse.
3	Information Disclosure via HTTP Headers – Server and application details were exposed through HTTP response headers.	Remove or restrict unnecessary server and application information from HTTP response headers.

Security Strengths

INTRODUCTION

In today's digital environment, websites play a critical role in business operations and user engagement. However, many websites are deployed with security misconfigurations that can expose them to potential risks if not regularly reviewed.

This report presents a passive vulnerability assessment of a publicly accessible website, conducted using ethical techniques without performing exploitation or active attacks. The assessment focuses on externally visible security weaknesses using industry-standard tools such as Nmap and OWASP ZAP (Passive Scan).

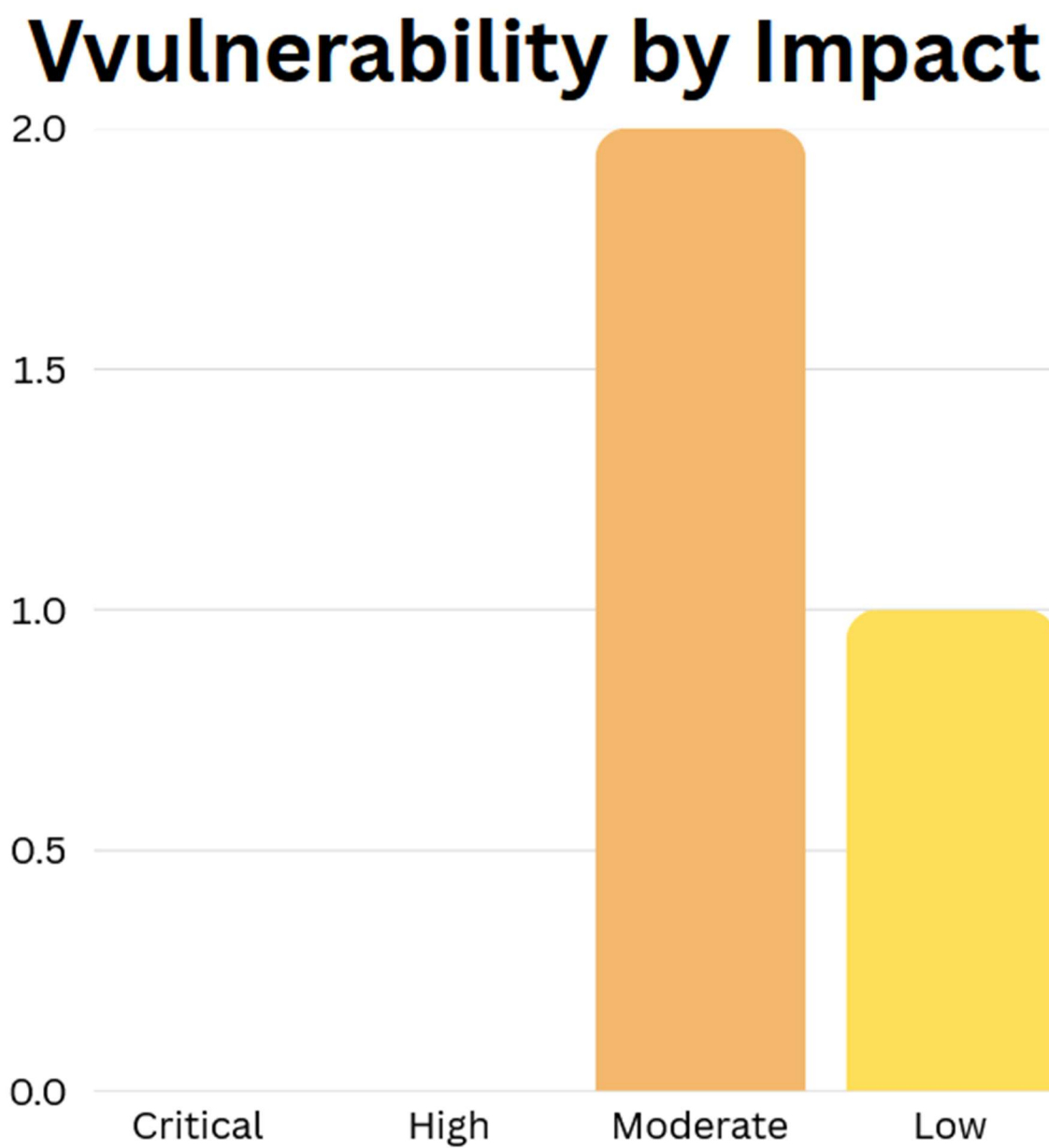
The objective of this assessment is to identify common security issues and present the findings in a clear and easy-to-understand manner to support basic security improvements.

SIEM alerts of vulnerability scans

During the assessment, the DI security team alerted FI engineers of detected vulnerability scanning against their systems. The team was successfully able to identify the FI engineer's attacker IP address within minutes of scanning and was capable of blacklisting FI from further scanning actions.

Vulnerabilities by Impact

The following chart illustrates the vulnerabilities found by impact:



External Penetration Test Findings

Missing Security Headers (Medium)

Description:	The website does not include several recommended HTTP security headers in its responses. The absence of these headers increases the attack surface and reduces the baseline security of the application.
Impact:	Medium
System/endpoint	http://testphp.vulnweb.com/
References:	NIST SP 800-53 Rev. 5 – SC-8: Transmission Confidentiality and Integrity

Exploitation Proof of Concept

The target application was assessed using SecurityHeaders.com. The scan revealed that several recommended HTTP security headers were missing from the server response, including:

- Content-Security-Policy (CSP)
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy

The absence of these headers may increase the application's exposure to attacks such as **Cross-Site Scripting (XSS)**, **Clickjacking**, **MIME-type sniffing**, and **information leakage**.

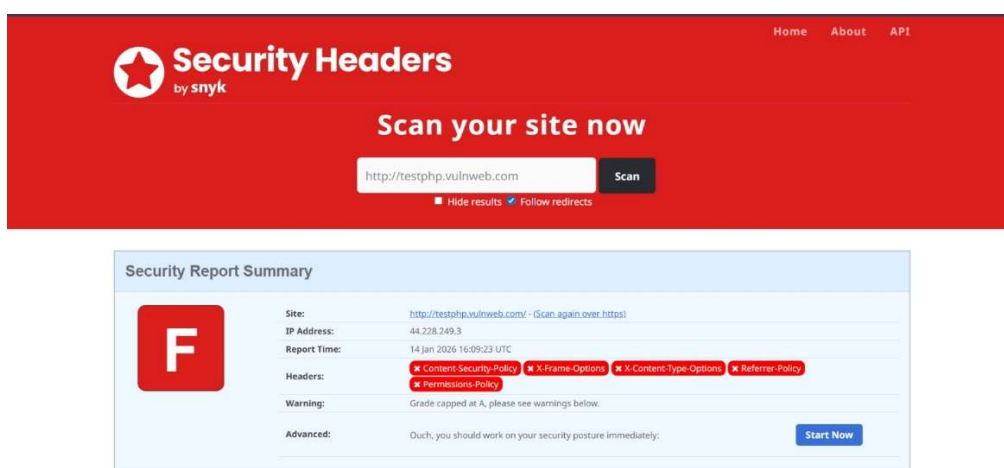


Figure 1 – SecurityHeaders.com scan showing missing security headers and F rating.

SecurityHeaders.com scan result assigned a grade of **F** and reported the above headers as missing.

Remediation

Who:	IT Team
Vector:	Remote
Action:	Item 1: Configure Content-Security-Policy (CSP) to restrict trusted content sources and mitigate XSS attacks. Item 2: Configure X-Frame-Options as DENY or SAMEORIGIN to prevent Clickjacking attacks. Item 3: Configure X-Content-Type-Options as nosniff to prevent MIME-type sniffing. Item 4: Configure Referrer-Policy to limit sensitive information leakage through HTTP referrer headers Item 5: Configure Permissions-Policy to restrict unnecessary browser features and APIs. Additionally, TCMS recommends that DC: ▪ Review web server configurations regularly. ▪ Validate security header implementation after deployment. ▪ Incorporate security header checks into routine security assessments and vulnerability scans.

Insecure Cookie Attributes (Medium)

Description:	Cookies were observed without recommended security attributes such as HttpOnly and Secure . An attacker may be able to steal or misuse user session information, which can lead to unauthorized access.
Impact:	Medium
System/endpoint	http://testphp.vulnweb.com/
References:	NIST SP 800-53 Rev. 5 – SC-23: Session Authenticity

During passive analysis using OWASP ZAP, the application response was found to contain a mismatch between the character encoding specified in the **HTTP Content-Type response header** and the charset declared within the **HTML document's meta tag**.

ZAP identified that the browser may receive conflicting charset information, potentially causing inconsistent content interpretation and undesired content-sniffing behavior.

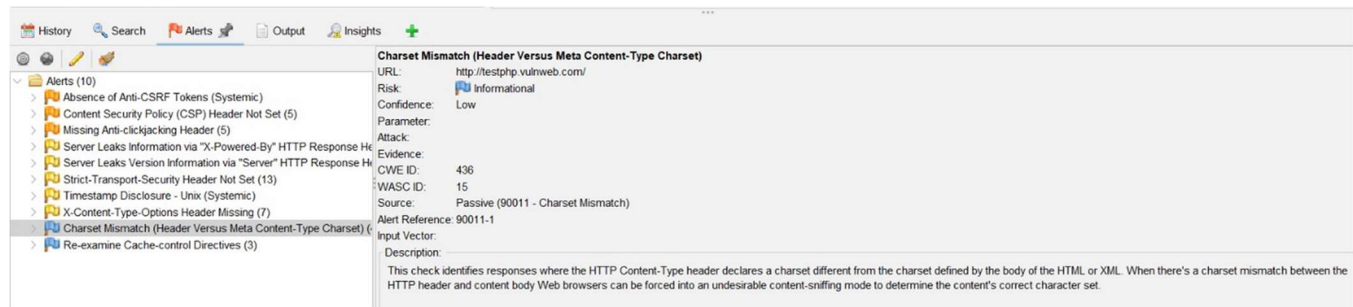


Figure 2 – OWASP ZAP detecting a Charset Mismatch between the HTTP response header and the HTML meta charset declaration.

SecurityHeaders.com scan result assigned a grade of **F** and reported the above headers as missing.

Remediation

Who:	IT Team
Vector:	Remote
Action:	Item 1 TCMS recommends ensuring that the character encoding specified in the HTTP response header matches the charset declared within the HTML document. Additionally, TCMS recommends that DC: ▪ Standardize UTF-8 encoding across the application. ▪ Configure the web server to consistently return the correct charset. ▪ Validate encoding settings during application deployment and security testing. ▪ Periodically review HTTP responses for charset consistency.

Information Disclosure via HTTP Headers (Low)

Description:	The website exposes server and application information through HTTP response headers. While this issue does not directly compromise the system, it increases the risk of reconnaissance and targeted exploitation.
Impact:	Low
System/endpoint	http://testphp.vulnweb.com/
References:	NIST SP 800-53 Rev. 5 – SI-11: Error Handling

Exploitation Proof of Concept

The target application was assessed using SecurityHeaders.com. The scan revealed that several recommended HTTP security headers were missing from the server response, including:

- Content-Security-Policy (CSP)
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy

The absence of these headers may increase the application's exposure to attacks such as **Cross-Site Scripting (XSS)**, **Clickjacking**, **MIME-type sniffing**, and **information leakage**.

Remediation

Who:	IT Team
Vector:	Remote
Action:	Item 1: Removing or mask unnecessary HTTP response headers that reveal server and framework information, including but not limited to: • Server • X-Powered-By • X-AspNet-Version • X-AspNetMvc-Version Additionally, TCMS recommends that DC: ▪ Configure the web server to suppress version information. ▪ Remove unnecessary technology disclosure headers. ▪ Regularly review HTTP responses for information leakage. ▪ Implement a secure server-hardening baseline across all web applications.

